

IT General Controls Testing Report

Harbourline Payments Ltd (fictional client)

Period tested: 1 January 2026 to 30 June 2026

Prepared by: Bhuvaneshwari Kundla

Date: September 2026

Supporting workbook: ITGC_Testing_Workbook.xlsx

Portfolio project. Harbourline Payments Ltd, its people, systems and data are entirely fictional and were created to practise IT audit testing. This is not an audit opinion.

1. Executive summary

I tested six key IT general controls (ITGCs) over LedgerCore, the payments and billing system that produces Harbourline's revenue and settlement figures. The controls cover the three standard ITGC areas: who can access the system, how changes reach it, and whether its data can be recovered.

Overall conclusion: the controls were designed appropriately and operated effectively during the period, except for two exceptions, each rated Medium. I found no evidence that either weakness was exploited.

Measure	Result
Controls tested	6
Controls effective	4
Controls with exceptions	2
Samples tested	60
Exceptions found	2 (3.3% of samples)

The two exceptions were:

- **EX-01:** a leaver kept system access for 8 business days after leaving.
- **EX-02:** an emergency change was deployed two days before it was approved.

Management has agreed actions for both (simulated responses in section 5).

2. Background and scope

Harbourline Payments Ltd is a fictional Dublin payment institution of about 180 staff, serving small and medium businesses. As a payment institution it falls within the scope of the EU Digital Operational Resilience Act (DORA). That makes access, change and backup controls a regulatory expectation as well as good practice.

Systems in scope

System	Purpose	Why in scope
LedgerCore application	Calculates fees, settlements, refunds and invoices	Produces figures used in financial reporting
LedgerCore production database (PostgreSQL)	Stores transaction and billing data	Direct data changes could alter reported figures
CI/CD deployment pipeline	Releases code changes to production	Controls how changes reach the financial system

Out of scope: physical and network security, end-user devices, and third-party SaaS tools. In a real engagement, controls at those providers would be covered by reviewing their own SOC reports.

3. Approach

For each control I followed the same three steps:

- **Design walkthrough:** confirmed with the control owner how the control works, and inspected one example to check that it would address the risk if it operated as described.

- **Operating effectiveness testing:** selected a sample from the full population for the period and checked each item against defined test attributes. I used inspection of records, comparison of dates, and re-calculation.
- **Evaluation:** where a sample failed, I looked for the root cause and any mitigating factors, rated the finding, and agreed a recommendation.

Before sampling, each population was checked for completeness, for example by agreeing the HR leaver report to payroll records. Sample sizes followed the frequency of each control (see the Sampling Guide sheet in the workbook).

Rating definitions

Rating	Meaning
High	Control failure could directly cause a material error or breach, with no mitigation.
Medium	A real weakness, but impact is limited or mitigating factors exist.
Low	A minor process or documentation gap.

4. Results by control

ID	Control	Domain	Sample	Exceptions	Conclusion
AC-01	Leaver access removed within 1 business day	Access	10 of 18	1	Exception noted
AC-02	Quarterly user and privileged access review	Access	2 of 2	0	Effective
CM-01	Changes tested and approved before deployment	Change	15 of 60	1	Exception noted
CM-02	Developers cannot deploy to production	Change	6 of 6	0	Effective
OP-01	Daily backups monitored; failures resolved	Operations	25 of 181	0	Effective
OP-02	Quarterly restore test within 4-hour RTO	Operations	2 of 2	0	Effective

Two observations support the effective conclusions. First, two backup failures in the OP-01 sample were alerted, ticketed and re-run the same day, so the control worked as intended. Second, emergency change CHG-1064 was approved by the CTO before deployment, which shows the emergency process can work correctly.

5. Findings and recommendations

EX-01 Delayed removal of leaver access (AC-01)

Item	Detail
Observation	One of 10 sampled leavers (E1019, Sales) kept LedgerCore access for 8 business days after their termination date, against a target of 1 business day.
Root cause	The leaver ticket sat in a Service Desk queue that was not monitored during a staff absence.
Risk	A former employee could access or change financial data.
Mitigating factors	System logs show no log-ins after termination. The account had read-only access.
Rating	Medium
Recommendation	Automate access removal from the HR leaver feed. Until then, add a daily check for unactioned leaver tickets.
Management response (simulated)	Agreed. Daily check introduced; automated feed planned for Q4 2026. Owner: IT Service Desk Lead. Target: 31 October 2026.

EX-02 Emergency change deployed before approval (CM-01)

Item	Detail
Observation	One of 15 sampled changes (CHG-1047, a hotfix for duplicate payment notifications) was deployed on 14 April 2026 but approved on 16 April 2026, with no documented emergency justification.
Root cause	The emergency process was followed verbally out of hours, and approval was not recorded at the time.
Risk	Unapproved changes could introduce errors into payment calculations without oversight.
Mitigating factors	A retrospective CAB review found the change worked as intended, with no adverse impact.
Rating	Medium
Recommendation	Block emergency deployments in the ticket workflow until CTO approval and justification are recorded. Review every emergency change at the next CAB.
Management response (simulated)	Agreed. Workflow updated. Owner: Change Manager. Target: 30 September 2026.

6. Framework alignment

The six controls also give Harbourline evidence for its wider obligations. The mapping below is indicative and should be confirmed against the source texts.

Control	ISO 27001:2022 Annex A	DORA	SOC 2 (TSC 2017)
AC-01	A.5.18, A.6.5	Art. 9(4)(c)	CC6.2, CC6.3
AC-02	A.5.18, A.8.2	Art. 9(4)(c)	CC6.2, CC6.3
CM-01	A.8.32, A.8.29	Art. 9(4)(e)	CC8.1
CM-02	A.5.3, A.8.31	Art. 9(4)(c) and (e)	CC8.1
OP-01	A.8.13, A.8.16	Art. 12	A1.2
OP-02	A.8.13, A.5.30	Art. 11, Art. 12	A1.3

7. Limitations

- This is a simulated exercise using invented data; it is not an audit opinion.
- Testing was sample-based, so it gives reasonable, not absolute, assurance that controls operated throughout the period.
- Only six key controls were tested. A full ITGC review would also cover areas such as new user provisioning, password settings, direct database changes and job scheduling.

Appendix: glossary

Term	Meaning
ITGC	IT general controls: the basic controls over access, change and operations that make system outputs reliable.
CAB	Change Advisory Board: the group that approves changes before release.
UAT	User acceptance testing: users confirm a change works before it goes live.
Segregation of duties	Splitting tasks so no single person can both make and release a change.
RTO	Recovery time objective: the maximum acceptable time to restore a system.
Population / sample	All items in the period, and the subset selected for testing.
Exception	A sample that did not meet one or more test attributes.